INDEPENDENT RESEARCH · NOVEMBER 11, 2026

FedRAMP monitoring: from scanner evidence to VDR and VER

How vulnerability scanners, remediation deadlines, and POA&Ms shaped the program, and where the approach changed.

Independent analysis of published rules, guidance, drafts, and public comments. Not official FedRAMP guidance.

The finding

FedRAMP began with a broad promise: agencies should be able to rely on continuing evidence that a cloud service was secure. Its operating model soon made vulnerability scanners a central source of that evidence. Monthly scans, asset inventories, severity-based deadlines, and prescribed reporting formats remained recognizable through 2024. The program tightened the quality and comparability of scanner output enough that providers could be required to change tools. [1 3 7 11 20]

That history includes real adaptations. FedRAMP allowed approved sampling, developed container-specific methods, reduced some POA&M reporting, proposed automated risk adjustments, and added API scanning. Those changes usually fitted newer technology into the existing assurance process. The 2025–2026 reforms went further: they made context, likely exploitation, and effects on agencies the basis for evaluating and responding to vulnerabilities. Scanners remain useful, but their findings no longer define the whole process. [11 12 13 15 17 19 28 29]

This is a history of published requirements and documented criticism, not a measurement of every authorization decision. The evidence supports a strong scanner focus. It does not establish that every agency enforced every provision identically, or that commercial objections alone caused the eventual reforms.

2011–2014 · A broad mandate becomes a recurring process

The December 8, 2011 OMB memorandum established FedRAMP as a shared approach to cloud authorization and continuous monitoring. It called for risk-based, cost-effective security and continuing visibility. It did not prescribe the later package of monthly scanner files, spreadsheet columns, and 30/90/180-day remediation deadlines. [1]

The underlying NIST framework was broader than scanning, too. SP 800-137 treated continuous monitoring as maintaining awareness of threats, vulnerabilities, assets, and control effectiveness. In SP 800-53, CA-7 covered continuous monitoring; RA-5 covered vulnerability scanning; CA-5 covered plans of action and milestones; SI-2 covered flaw remediation. Many frequencies and deadlines were left for organizations to define. FedRAMP supplied more specific expectations for participating cloud services. [2 4]

The first recovered FedRAMP Continuous Monitoring Strategy Guide, dated June 2012, already connected scans, inventories, remediation, control assessments, incidents, and changes. Its schedule required monthly

operating-system/infrastructure scans, but quarterly web-application and database scans. It said high-risk vulnerabilities **should** be mitigated within 30 days and moderate-risk vulnerabilities **must** be mitigated within 90 days. The familiar universal shorthand “30/90/180 since 2011” is therefore misleading. [3]

By the June 2014 revision, operating-system, web-application, and database scanning were monthly, and high- and moderate-risk remediation carried 30- and 90-day requirements. Independent annual assessment remained part of the larger program. This created the durable rhythm: collect recurring evidence, compare it with the authorized system, track weaknesses, and show that overdue work is being addressed. A monthly reporting cycle was never a license to ignore a vulnerability between reports. [5]

An August 2014 draft reporting guide proposed a standard monthly summary derived from scans and POA&Ms. Its rationale was consistent information for authorizing officials; its proposed record included every unique scanner finding and documented deviations. This is an early view of the reporting design taking shape, not a final requirement inferred from a draft. The original attachment was not recovered, but its government-authored text survives in a procurement archive. [33]

2015–2017 · Scanner evidence becomes an enforceable specification

The May 2015 JAB P-ATO Vulnerability Scan Requirements made the preferred evidence unusually concrete. These were requirements for the Joint Authorization Board’s provisional authorization process; they should not be silently attributed to every agency authorization. They required monthly scans, raw native scanner output, reconciliation with inventory, and consistent tools between the provider and independent assessor. Changing scanners could mean continuing the old tool until its outstanding findings were resolved. [7]

Credentialed scans needed sufficient access. All non-destructive checks had to be enabled. Unauthenticated or incomplete scans could be rejected unless a relevant exception had been approved. Scanning had to cover the boundary, with approved sampling available for sufficiently uniform systems. This was more than a request to demonstrate a sound vulnerability-management program: it specified characteristics of the instrument and the evidence it produced. [7]

There were consequences. The guide described rescanning, requiring an independent assessor to perform future scans, corrective action plans, and possible JAB authorization revocation and Marketplace removal. Later performance guidance formalized escalation for repeated deficient scans and aging findings. Those documents establish enforcement authority and escalation criteria; they do not tell us how often revocation actually happened. [7] [10]

The September 2015 POA&M completion guide also standardized the administrative record. A POA&M, or plan of action and milestones, tracked weaknesses and planned remediation. The template required specified columns, scanner identifiers, detection dates, original and adjusted risk, and scheduled completion dates. Yet exceptions were part of the system: false positives, risk adjustments, operational requirements, and vendor dependencies could be documented and reviewed. Where a vendor fix was unavailable, providers had to check for it regularly rather than pretend a patch existed. [8]

The 2017 FedRAMP Tailored approach for low-impact SaaS simplified parts of assessment, including allowing an assessor to observe provider scans or use approved verification methods. It retained applicable monthly OS, web, and database scanning and the high/moderate remediation schedule. Simplification did not generally displace the scanner-based model. [9]

2018 · More consistency, with some room for scale and risk

The March 20, 2018 Vulnerability Scanning Requirements replaced the JAB-specific guide and addressed both JAB and agency authorizations. They specified machine-readable output, CVE identifiers, NVD CVSS base scores, adequate asset identification, current signatures, and approved scanner configurations. Moderate and High systems needed authenticated scanning wherever possible, with full authorization. Providers had to enable all non-destructive detections. [11]

The document explicitly warned that some providers might have to change scanners or work with their vendors. Only compliant scanning tools would be accepted, with a September 1 transition deadline. This did not mandate a particular brand. It did make conformance to FedRAMP's scanner-output model a condition of acceptable evidence. The stated rationale was consistent, higher-quality information that agencies could analyze across services. [11]

Two companion efforts acknowledged the limits of a literal machine-by-machine approach. Sampling guidance formalized how standardized images and asset classes could support representative scans in large or elastic environments, subject to assessor validation and authorizing-official approval. Sampling had already been possible in 2015; 2018 supplied a more developed method. [7] [12]

A separate **draft** Automated Vulnerability Risk Adjustment Framework proposed using environmental CVSS factors to adjust scanner findings automatically. It contemplated a pilot, assessor validation, and official approval; automatic reductions were generally limited to one severity level. It is evidence that FedRAMP was considering contextual risk well before VDR. It is not evidence that unrestricted automated adjustment became a universally available final policy. [13]

The POA&M history contains a particularly important qualification. The January 2018 revision, documented in the later completion guide, stopped requiring every scanner finding to be entered immediately: scanner findings needed POA&M entries when overdue. Non-scanner findings and deviation requests still had to be included. Raw scan data still went to the authorizing official, who could require all open risks on the POA&M. The same revision history introduced the 180-day low-risk threshold. [14] [15]

Meanwhile, the scanning guide still required each unique vulnerability to be tracked separately, using the scanner's identifier, and prohibited grouping different vulnerabilities into one POA&M item. Read alongside the completion guide, this created a practical interpretation problem: which findings needed entries, and how should eligible findings be represented? It would be inaccurate to describe the entire period as requiring every fresh scanner result in a POA&M, but equally inaccurate to describe the reporting rules as flexible about grouping. [11] [15]

The 2018 performance guide reinforced both evidence quality and deadlines. For example, repeated scans with at least 10 percent unauthenticated results could lead to a corrective action plan. Five high findings over 30 days triggered review; persistence beyond 60 days could trigger a plan. These escalation thresholds were not extensions of the underlying remediation deadlines. [10]

2020–2021 · Containers change where the evidence comes from

The August 2020 container-scanning draft is a clear response to technological change. FedRAMP's announcement said industry had requested guidance to bridge compliance gaps between traditional and containerized systems. The draft addressed hardened images, automated build and deployment processes, image scans, sensors, registries, and rapidly changing inventories. It already discouraged directly scanning production containers except through independent security sensors. [16]

The March 2021 final guidance retained that approach after technical exchange and public comment. It recognized immutable infrastructure: scan images, control deployment, track image-to-instance relationships, and replace containers rather than patching them in place. It required internal tracking of deployed instances without automatically requiring every instance in the submitted inventory workbook. Security sensors could provide continuing visibility. [17]

This was substantive adaptation, not just a change of terminology. Traditional host scans were poorly matched to short-lived containers; the guidance moved work into image repositories and deployment pipelines. It still connected that evidence to a 30-day scanning window, monthly submissions, assessor validation, and the existing control baselines. The final document allowed six months to transition and requested transition plans within one month. [17]

The November 2021 POA&M guide preserved the distinction between overdue scanner findings and other weaknesses. Vendor dependencies, false positives, risk adjustments, and operational requirements remained documented workflows. Those mechanisms made contextual judgments possible, but required providers to translate them into FedRAMP's record and approval process. [15]

2022–2024 · New threats and interfaces, the same reporting backbone

In June 2022, FedRAMP added POA&M template columns for CVEs and the due dates associated with CISA's Known Exploited Vulnerabilities directive, BOD 22-01. This introduced a clearer distinction between severity-based aging and vulnerabilities known to be exploited. A high, moderate, or low label alone no longer described every applicable remediation deadline. [18]

The 2023 Rev. 5 transition added API scanning where applicable. The need was openly questioned: at the Federal Secure Cloud Advisory Committee, Bo Berlas asked whether monthly OS, web, and database evidence adequately represented services built around APIs, multiple clouds, microservices, and containers. The PMO answered by pointing to container guidance and the new API requirement. That exchange documents both the criticism and the program's technological response. [19]

The February 15, 2024 scanning document consolidated the requirements, including containers. It retained monthly scans, raw machine-readable evidence, CVSS base ratings, approved configurations, and separate entries for unique vulnerabilities. It again said only compliant scanners would be accepted. It also refined container image scanning, registry controls, encryption, and the consistency of remediation scan output. The cover says version 2.0 while the revision table calls the same dated release 3.0; the date is the safer identifier. [20]

OMB's July 25, 2024 modernization memorandum called for more automation, reuse, and alignment with commercial cloud practices. That supplied a broader policy direction. It did not, by itself, erase the detailed scanning rules then in use. The evidence through 2024 shows an expanded and refined scanner-centered process, with meaningful exceptions and newer collection methods, rather than wholesale replacement. [21] [20]

What the templates made providers do

The templates were part of the operating model, not incidental paperwork. The POA&M workbook turned findings into dated, categorized remediation records; the inventory workbook connected evidence to assets; executive summaries and deviation forms made status and exceptions reviewable. Separating the inventory from the POA&M, adding approval fields, and adding KEV columns changed the workflow without removing it. The repository's source inventory distinguishes recovered workbooks from revisions known only through later change logs. [8] [15] [18] [31]

2025 · Commercial objections shape successive drafts

The first major replacement proposal was RFC-0008, opened in May 2025. It proposed continuous reporting through key security metrics, with more use of providers' existing capabilities. It did not move forward in that form. FedRAMP's official RFC register says feedback informed the subsequent Continuous Vulnerability Management proposal, RFC-0012, opened in July. [22] [23] [24]

Public feedback helps explain why a scanner-centered workflow could be difficult for mature commercial services. A commenter using the handle **mswilson** described severity and false-positive problems when a scanner or CVE mapping treated code as vulnerable without adequately considering how it was actually used. Another practitioner, **cb-axon**, described the work of handling hundreds of kernel findings separately even when one patch addressed them. These are accounts of implementation burden, not proof that the underlying vulnerabilities were harmless. [25] [26]

Confluent's formal response to RFC-0012 identified a different mismatch: unauthenticated network scanning could require opening otherwise closed access paths in containerized environments already monitored with host-based agents. The company also asked for clearer terminology and workable assessment timelines. This is direct evidence of a commercial service arguing that mandated assessment methods could conflict with its security architecture. It concerns the **draft replacement**, so it cannot simply be backdated as a description of every older FedRAMP requirement. [27]

RFC-0012 itself moved toward contextual evaluation and allowed grouping, but still proposed detailed schedules. It recommended assessing internet-reachable resources every three days and mitigating credibly exploitable internet-reachable vulnerabilities within three days. These were **SHOULD** provisions, not universal three-day MUST deadlines. A separate provision required remaining vulnerabilities to be mitigated or remediated within six months. The proposal expressly was not an operative standard. [23]

The official outcome says substantial public feedback led to significant modification and release as Vulnerability Detection and Response. This establishes a documented connection between consultation and the resulting standard. It does not establish that any one company, complaint, or proposed tool caused a particular final rule. Meanwhile, the November 2025 legacy Continuous Monitoring Playbook consolidated older documents for services still following that process. The two developments overlapped. [24] [30]

2026 · VDR and VER change what counts as the unit of work

The current Vulnerability Detection and Response rules (VDR) and Vulnerability Evaluation and Reporting rules (VER) separate discovery and response from evaluation and reporting. They cover weaknesses found through scanning, threat intelligence, disclosure programs, penetration tests, assessments, and other methods. They also address control weaknesses. A provider's responsibility extends beyond the set of CVEs a scanner can enumerate. [28] [29]

VER requires contextual evaluation of likely exploitability, internet reachability, and potential effects on federal customers. Its Potential Agency Impact N-rating, or PAIN, expresses that last dimension. Logical grouping is encouraged. VDR explicitly says providers should not weaken a system to make vulnerability detection work. Those choices address recognizable concerns in the earlier public discussion, although the published record does not assign each change to an individual comment. [28] [29]

The change does not eliminate deadlines or accountability. Evaluation and response expectations vary by certification class and circumstances. For example, VDR's prioritized-response rule gives Class C providers a two-day **SHOULD** timeframe for reducing the impact of a likely exploitable, internet-reachable PAIN-5 vulnerability. The clock runs from evaluation, and the target is impact reduction. This is not a blanket two-day patch deadline for every scanner finding. Separate expectations govern evaluation after detection, other risk levels, and known exploited vulnerabilities. [28] [29]

Reporting also continues. VER requires at least monthly human-readable activity reports and details such as detection and evaluation times, reachability, exploitability, impact changes, planned reductions, overdue explanations, and disposition. JSON availability and refresh expectations vary by class. Vulnerabilities not fully mitigated or remediated within 192 days of evaluation must be categorized as accepted vulnerabilities and reported accordingly; "accepted" does not mean invisible. [29]

As of November 11, 2026, these are published rules with a transition still underway. For Rev. 5, optional adoption began July 4; mandatory adoption is December 7, 2026, with a corrective-action grace period ending March 7, 2027. Notice NTC-0014 links the accelerated transition to CISA BOD 26-04. It also records the preceding 20x release in late 2025 and Rev. 5 beta in early 2026. It would be premature to describe every service as already operating under VDR/VER. [28] [29] [32]

What persisted, and what actually changed

The enduring obligation is straightforward: know what is in the service, find weaknesses, address them promptly, retain evidence, and keep authorizing agencies informed. Independent review and consequences for inadequate assurance also persisted. What hardened between 2012 and 2024 was a particular way of making that obligation inspectable: scheduled scans, comparable raw results, fixed severity clocks, inventory matching, and controlled exceptions. [3] [7] [10] [20]

Changes before 2025 were real but generally bounded. Monthly web and database scans increased coverage. Sampling addressed scale. The 2018 POA&M change reduced immediate reporting of scanner findings. The risk-adjustment draft explored contextual scoring. Container rules accommodated images and pipelines. KEV fields responded to exploitation evidence, and API scanning expanded the surfaces examined. It is fair to say the scanner model endured; it is not fair to say FedRAMP ignored every change in cloud technology.

The newer approach gives the provider more responsibility for explaining which weaknesses can cause harm and how that harm is being reduced. It also demands evidence for those judgments. Whether that produces better security with less administrative work is an implementation question this historical record cannot yet settle.

Controls behind the history

Control	Its role in this history
CA-7 · Continuous monitoring	The broader assessment, metrics, analysis, and reporting program. Scanning is one input.
RA-5 · Vulnerability monitoring and scanning	Scanning in Revs. 3 and 4; explicitly titled “Vulnerability Monitoring and Scanning” in Rev. 5. FedRAMP adds program-specific expectations.
CA-5 · Plan of action and milestones	Planned remedial action and updates from assessments and monitoring. The spreadsheet is an implementation of that obligation.
SI-2 · Flaw remediation	Identifying, correcting, and verifying fixes; related to, but not identical with, scan frequency.
CM-8 · System component inventory	The asset record needed to establish coverage, including image and instance relationships.

These roles span NIST revisions; a control’s existence does not prove that every later FedRAMP parameter applied in 2011. Current VDR/VER rules should be read with their own class, applicability, and effective-date fields. [4] [6] [28] [29]

About the evidence

This independent report covers the published policy lineage from 2011 through November 11, 2026, concentrating on changes through 2024 and the transition to VDR/VER. It uses the inforegs archive, the FedRAMP MCP corpus, live official documents, archived government files, and public comments. Dates come from documents rather than download paths. Drafts and comments are identified as such. Historical government documents held by third-party mirrors are labeled in the references.

The search recovered the principal document families and several important drafts, but not every edition of every workbook or guide. The original 2014 draft reporting attachment and some intermediate revisions remain gaps; archived text of that draft was recovered. Google access was attempted but blocked by the available browser environment and search challenge; general web search and direct archive retrieval supplied the external discovery instead. The repository contains the edition inventory, source hashes, claim notes, and retrieval limitations. The report does not claim an exhaustive archive or a census of enforcement decisions.

Sources

Numbers in the text link here. Historical mirrors preserve government-authored documents; they are not current policy authorities. Locators refer to the cited edition.

1. OMB · Establishing FedRAMP, December 8, 2011
Program responsibilities and continuous monitoring. Retrieved from inforegs.
Read source

2. NIST · SP 800-137, September 2011
Sections 2–3: continuous monitoring strategy and program. Inforegs original.
Read source

3. FedRAMP · Continuous Monitoring Strategy Guide v1.0, June 2012
Ongoing assessment schedule, RA-5 and SI-2 rows. Government document preserved by the Center for Regulatory Effectiveness. Cover June 27; revision table June 14.
Read source

4. NIST · SP 800-53, Revisions 3 and 4
CA-5, CA-7, RA-5, SI-2 and CM-8. Rev. 3 (2009, updated 2010); Rev. 4 (2013, updated copy). Inforegs originals.
Revision 3 · Revision 4

5. FedRAMP · Continuous Monitoring Strategy Guide v2.0, June 6, 2014
Ongoing assessment schedule and annual assessment. Historical SitesUSA document.
Read source

6. NIST · SP 800-53 Revision 5, September 2020
CA-5, CA-7, RA-5, SI-2 and CM-8. Inforegs original.
Read source

7. FedRAMP · JAB P-ATO Vulnerability Scan Requirements v1.0, May 27, 2015
PDF pp. 5–7: scan deliverables, sampling, rejection and escalation. Historical SitesUSA copy.
Read source

8. FedRAMP · POA&M Template Completion Guide v1.1, September 2015
Sections 2–3: columns, deviations and vendor dependencies. Cover September 3; later revision history September 1. Historical SitesUSA copy.
Read source

9. FedRAMP · Tailored LI-SaaS Continuous Monitoring Guide v2.0, August 23, 2017
Scanning, remediation and assessment schedule. Government guidance preserved by Carahsoft.
Read source

10. FedRAMP · Continuous Monitoring Performance Management Guide v2.1, February 21, 2018
Revision history and escalation tables. Government document preserved in a 2022 third-party GitHub mirror.
Read source

11. FedRAMP · Vulnerability Scanning Requirements v1.0, March 20, 2018
Sections 3–4: scanner properties, POA&M entries and transition. A 2022 mirror capture of the 2018 edition, not a 2022 edition.
Read source

12. FedRAMP · Vulnerability Scan Sampling Guidance v1.0, March 20, 2018
Eligibility, asset classes and approval. Government document in a third-party GitHub mirror.
Read source

13. FedRAMP · Draft Automated Vulnerability Risk Adjustment Framework v0.1, March 20, 2018
Draft pilot, environmental scoring and limits on automated adjustment. Third-party mirror; not treated as final policy.
Read source

14. FedRAMP · Continuous Monitoring Strategy Guide v3.2, April 4, 2018
Revision history and ongoing assessment table. Third-party mirror. The January 31 v3.0 change added low-risk 180-day remediation.
Read source

15. FedRAMP · POA&M Template Completion Guide v2.2, November 23, 2021
Revision history; section 2 column instructions; section 3 and footnote on late-only scanner findings. Third-party mirror.
Read source

16. FedRAMP · Container scanning draft v1.0, August 14, 2020
Draft sections 2–4 and public-comment announcement (comments due September 11). Retained Internet Archive PDF and mirrored government announcement.
Draft PDF · Draft announcement

17. FedRAMP · Vulnerability Scanning Requirements for Containers v1.0, March 16, 2021
Sections 3–4 and release announcement. Final requirements following technical exchange and public comment.
Final PDF · Final announcement

18. FedRAMP · POA&M template update, June 28, 2022
Announcement identifies columns AC (BOD 22-01 due date) and AD (CVEs). Mirrored government announcement.
Read source

19. GSA · FSCAC outstanding questions, October–November 2023
October 26 exchange between Bo Berlas and FedRAMP PMO; page updated August 21, 2024.
Read source

20. FedRAMP · Vulnerability Scanning Requirements, February 15, 2024
Sections 3–4, printed pp. 1–6. Retained Internet Archive capture, February 28. Cover says v2.0; revision table says v3.0.
Read source

21. OMB · M-24-15, July 25, 2024
Modernizing FedRAMP: commercial practices, automation and continuous monitoring. Inforegs original.
Read source

22. FedRAMP · RFC-0008, May 2025
Draft Continuous Reporting Standard; introductory rationale and proposed metrics. Did not advance in this form.
Read source

23. FedRAMP · RFC-0012, July–August 2025
Draft Continuous Vulnerability Management Standard; proposal, timeframes and applicability. Opened July 15; closed August 21.
Read source

24. FedRAMP · Official RFC register
Published outcomes for RFC-0008 and RFC-0012. Checked November 11, 2026.
Read source

25. Public comment · mswilson, discussion 24
Practitioner testimony about CVE mapping, severity and false positives; not a FedRAMP rule.
Read source

26. Public comment · cb-axon, discussion 59
Practitioner testimony about kernel findings, grouping and administrative work; not a FedRAMP rule.
Read source

27. Public comment · Confluent response to RFC-0012
Commercial provider response concerning unauthenticated scanning, architecture and timelines; not a FedRAMP rule.
Read source

28. FedRAMP · Vulnerability Detection and Response, 2026
VDR-CSO-DET, MSP and RES; VDR-TFR-PVR and KEV; applicability fields. Live rules checked November 11, 2026.
Read source

29. FedRAMP · Vulnerability Evaluation and Reporting, 2026
VER-EVA-ELX/EIR/EPA/GRV; VER-RPT-PER/VDT/AVI; VER-TFR-MHR/MAV/MRH/EVU. Live rules checked November 11, 2026.
Read source

30. FedRAMP · Continuous Monitoring Playbook v1.0, November 17, 2025
Replacement-document table and continuing legacy workflow. Preserved government website document.
Read source

31. FedRAMP · Baselines and reporting workbooks
Recovered Rev. 4 baseline, December 2021 Rev. 5 public-comment draft, later legacy baseline and POA&M workbooks, monthly executive summary and deviation form. Snapshot dates do not establish original issuance dates; see edition inventory.
Rev. 4 baseline · Rev. 5 draft (2021) · Legacy baseline · Rev. 4 POA&M · Legacy POA&M · Monthly summary · Deviation form

32. FedRAMP · NTC-0014, June 16, 2026
BOD 26-04 response, VDR/VER transition history and accelerated mandatory adoption schedule.
Read source

33. FedRAMP · Draft Continuous Monitoring Monthly Reporting Summary Guide, August 20, 2014
Government-authored draft text reproduced by GovTribe with the August 2014 request for comment; original DOCX not recovered. Reporting overview, finding granularity and deviation instructions. Archive access may be restricted.
Read source